🏫 自習室入退室管理システム：内部技術仕様書 (Technical Reference)

本ドキュメントは、システムの核心となるロジック、データ物理構造、およびセキュリティ戦略を網羅した、**「開発・保守の奥義」**となるテクニカルリファレンスです。

---

1. 認証と認可の多層防御 (Auth & Security)

1.1 NextAuth.js の拡張ロジック

- **ドメイン検証**: `NextAuth` の `signIn` コールバック内で、`user.email` が `@niigata-meikun.ed.jp` を含むかを正規表現で検証。これ以外のログインは、OAuth 認可が成功しても Next.js レベルで弾かれます。
- **認可middleware (`proxy.ts`)**: Next.js 16 の Edge Middleware 規約に従い、ページリクエストがサーバーサイドレンダリングされる前に、以下の条件を検証。
  - **管理者権限**: セッション内の `email` が環境変数 `ADMIN_EMAILS` (カンマ区切り) に含まれているか。
  - **スキャン権限**: 管理者のみが `/scanner` 以下へのフルアクセス権を持ちます。

1.2 QRコード (JWT) の精密仕様

- **暗号アルゴリズム**: HMAC SHA256 (HS256)
- **秘密鍵**: サーバー上の環境変数 `NEXTAUTH_SECRET` (32文字以上のランダム文字列)
- **有効期限戦略**:
  - フロントエンド: 30秒ごとに fetch して画面更新。
  - バックエンド: `expiresIn: "60s"` 。これにより、30秒間の最大遅延（ネットワーク瞬断等）を許容しつつ、不正コピーの賞味期限を最短化しています。

---

2. データベース物理設計とトランザクション (PostgreSQL)

2.1 データ・モデリングの極意

詳細は `prisma/schema.prisma` を参照。

モデル	物理的な役割	設計上のポイント
`User`	全てのステート保持	`currentStatus` と `currentSeat` の整合性を常に保つ。
`AttendanceLog`	時系列の証跡	インデックスを `timestamp` に張り、履歴取得を高速化。
`SystemSetting`	動的な設定 (JSON)	`key` にインデックスを持たせ、頻繁な参照に耐える。

2.2 原子性の確保 (`$transaction`)

入退室処理 API (`/api/checkin`) では、以下の処理を 1つのトランザクションとして実行します。

1. `User.update` で在室ステータスの反転。
2. `AttendanceLog.create` で打刻記録。 **メリット**: DB 接続障害などでどちらか一方が失敗した場合、もう一方もロールバックされるため、「在室になっているのに履歴がない」といった不整合が絶対に起きません。

---

3. 重要アルゴリズム詳細 (Core Logic)

3.1 1分間連続スキャン防止ロジック

- **目的**: 受付での誤った連続スキャンや、悪意ある連打を防ぐ。
- **実装**: `AttendanceLog.findFirst` で該当 `userId` の最新履歴を取得。 `now() - timestamp < 60000ms` であればエラー (429) を返す。

3.2 保護者承認 (Magic Link) のべき等性

- **課題**: メール内のリンクが何度もクリックされることによる、予期せぬ状態変更。
- **解決策**:
  - 承認用 JWT トークンの生成。
  - 処理成功時に、そのトークンのシグネチャ（署名部分）を SHA-256 でハッシュ化。
  - `SystemSetting` に `key = used_permission_[Hash]` で保存。
  - 次回アクセス時、このキーが DB に存在すれば「使用済み」として拒否。

---

4. インフラ構成とネットワーク (OPS)

4.1 Docker / Next.js 連携

- **実行環境**: `node:18-alpine` （極限までの軽量化とセキュリティ）。
- **ポート設定**: コンテナ内部 `3000` -> ホスト側 `3000` (Docker Compose マッピング)。

4.2 Nginx リバースプロキシの秘伝設定

```
location / {
    proxy_pass http://localhost:3000;
    proxy_http_version 1.1;
    proxy_set_header Upgrade $http_upgrade;
    proxy_set_header Connection 'upgrade';
    proxy_set_header Host $host;
    proxy_cache_bypass $http_upgrade;
    proxy_set_header X-Forwarded-For $proxy_add_x_forwarded_for;
    proxy_set_header X-Forwarded-Proto $scheme;
}
```

---

5. 運用保守チェックリスト (Maintenance)

- **定期ログ監視**: `sudo docker compose logs --tail=50 -f app`
- **DB バックアップ**: Supabase ダッシュボードからの毎日自動バックアップ。
- **年度替わりの儀式**: `PROJECT_HANDOVER.md` の「年度更新」セクションに従い、一律リセットを実行。

> *このシステムが、後代の「明訓パソコン部」メンバーによって愛され、磨き続けられることを。 2026年4月5日*